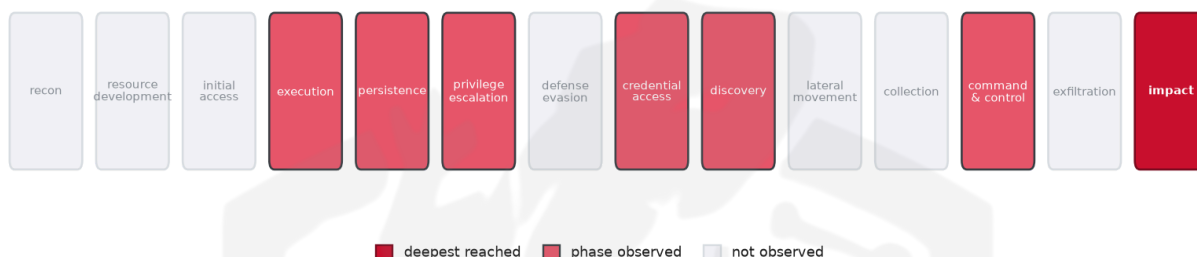


THREAT REPORT: KATARU IOT MALWARE EXPLOITS PUBLIC LPE VULNERABILITIES

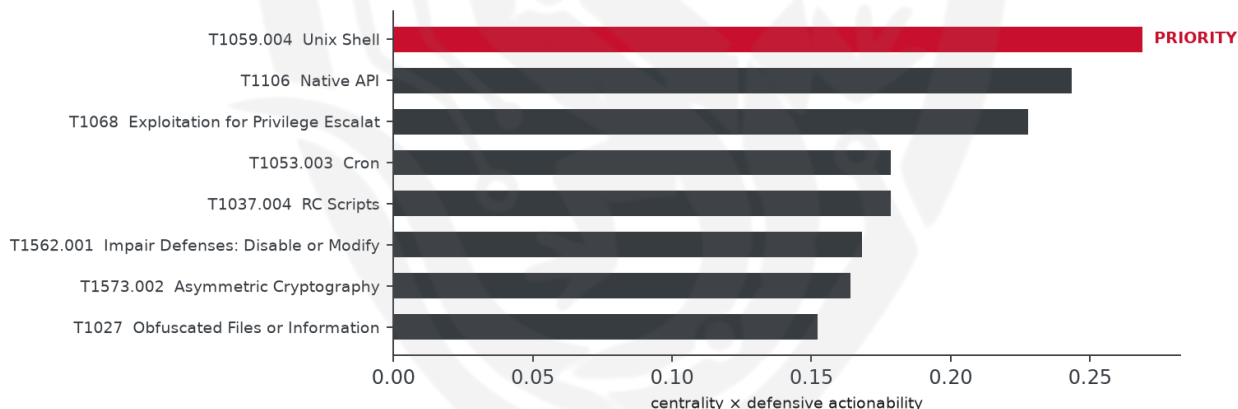
Visual Summary

Kill-Chain Reach — Critical (deepest phase reached: impact)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

The observed cluster is deploying the KATARU and Mirai IoT malware families to exploit the publicly disclosed vulnerability CVE-2026-46300. Victim details such as country or sector are not provided in the source. The priority defensive action is to constrain PowerShell for unprivileged users (Constrained Language Mode + AppLocker), enable script-block logging, block wscript/cscript where unnecessary, and promptly patch CVE-2026-46300 on all affected systems.

Threat Overview

The source does not identify a specific threat actor. The activity involves the KATARU and Mirai malware families leveraging the local-privilege-escalation flaw CVE-2026-46300. No information on targeted countries or sectors is available.

Attack Chain and Priority Control

The campaign follows a typical IoT-malware chain: initial credential-guessing (T1110.001) and network discovery (T1016, T1082), exploitation for privilege escalation via CVE-2026-46300 (T1068), execution of native APIs (T1106) and Unix shell commands (T1059.004), deployment of obfuscated payloads (T1027), establishment of persistence through cron jobs (T1053.003) and systemd services (T1543.002), and finally large-scale flooding attacks (T1498.001, T1499.002).

Priority technique: T1059.004 Unix Shell

Concrete control: Constrain PowerShell for unprivileged users (Constrained Language Mode + AppLocker); enable script-block logging; block wscript/cscript where unneeded. In parallel, patch CVE-2026-46300 on all affected systems.

Infrastructure and Corroboration

The malicious infrastructure is hosted by Hoang Dieu Cloud Computing Company Limited, as reported by the source. AbuseIPDB flags one indicator associated with the campaign at 100 % confidence as malicious. Abuse.ch independently corroborates the presence of the Mirai malware family within this activity.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1110.001 Password Guessing
- T1498.001 Direct Network Flood
- T1053.003 Cron
- T1082 System Information Discovery
- T1499.002 Service Exhaustion Flood
- T1106 Native API
- T1016 System Network Configuration Discovery
- T1059.004 Unix Shell
- T1562.001 Impair Defenses: Disable or Modify Tools
- T1068 Exploitation for Privilege Escalation
- T1027 Obfuscated Files or Information
- T1573.002 Asymmetric Cryptography
- T1095 Non-Application Layer Protocol
- T1037.004 RC Scripts
- T1543.002 Systemd Service
- T1105 Ingress Tool Transfer

Analytical Scores

- Priority technique (graph chokepoint): T1059.004 Unix Shell (centrality 0.3361).
- Operational risk: Critical (score 1.0, reaches impact).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.3086; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Rocke	0.3086
Cobalt Group	0.2724
TA2541	0.2694
Tropic Trooper	0.2624
FIN8	0.2624

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 100%.
- Malware families corroborated by abuse.ch: Mirai.
- Note: enrichment raises the severity signal (an IOC at or above 80% AbuseIPDB confidence, or a confirmed malware-family hit). This is context, not a change to the source assessment.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
IP	160[.]191[.]242[.]92	AbuseIPDB 100% (VN) · AS153416 Hoang Dieu Cloud Computing Company Limited
Hash	9d7cd4948a1fcbaeadc425752f9a933bd6fc41eede030dffd7b99b3bc51d5	Mirai
Hash	cc76bc218627279ecb4d0ce74ad2651e9db9e3e843e35d6569576e056e3a9218	Mirai
Hash	13382c16e2401b07451577b46e634b8031ec254d98b876e59692b5fa22abc1d4	Mirai

Type	Indicator	Context
Has h	6fbae3505ae0d638b820165c572d548ce92dda71e82dc47e8efe13f30617f35f	Mirai
Has h	9d87e6615c810907443ebd5e915f3b35099c3b5c6b6c684637138a7f8ec9cebc	Mirai
Has h	3bb6cd6fda610f65fd05741e20306f59	Mirai
Has h	92bd261aab30589e89ac0e77beeadddd	Mirai
Has h	9d754cdf176c21649645444b56cb0e0e	Mirai
Has h	2fa81859fc4ff50f43ff16f5cee544f6e84cf5af	Mirai
Has h	7105b13258702a2d55c8a7a0f100bbe25891e54f	Mirai
Has h	ddd07abb4c1077a6b6e54d61a8f6026360ac6379	Mirai
Has h	77c6547ba3f5769222b0c91d035abd540f42bf01	

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1059.004 Unix Shell (execution)
- **Observed here:** T1059.004 Unix Shell was the only execution technique observed in this campaign, so the pivot is projected from cross-actor behaviour.
- **Projected pivot:** T1574 Hijack Execution Flow (execution)
- **Basis:** of the 32+ groups that use Unix Shell, this pairing runs 1.2x above base rate, a disproportionately-coupled move rather than the obvious one.

If the Unix shell is blocked, the threat actor could pivot to hijacking an existing legitimate process by injecting malicious code or manipulating the process's memory to execute their payload, thereby preserving execution without needing a shell (T1574). Defenders should apply the specific MITRE ATT&CK mitigation for this technique; add host/network detections and least-privilege controls around it.

Also plausible (same tactic): T1569 System Services (n=16, lift 1.3), T1559 Inter-Process Communication (n=13, lift 1.3)

- **Defensive countermeasure:** Apply the specific MITRE ATT&CK mitigation for this technique; add host/network detections and least-privilege controls around it.

